



中华人民共和国国家标准

GB/T 34080.3—2021

基于云计算的电子政务公共平台 安全规范 第3部分:服务安全

Security specification of electronic government common platform
based on cloud computing—Part 3:Service security

2021-03-09 发布

2021-10-01 实施

国家市场监督管理总局 发布
国家标准化管理委员会

目 次

前言	III
引言	IV
1 范围	1
2 规范性引用文件	1
3 术语和定义	1
4 服务安全等级划分	1
5 服务安全要求	2
5.1 服务访问控制	2
5.1.1 基本型服务安全要求	2
5.1.2 加强型服务安全要求	2
5.1.3 高等级服务安全要求	2
5.2 服务传递保护	2
5.2.1 基本型服务安全要求	2
5.2.2 加强型服务安全要求	2
5.2.3 高等级服务安全要求	3
5.3 服务监控	3
5.3.1 基本型服务安全要求	3
5.3.2 加强型服务安全要求	3
5.3.3 高等级服务安全要求	3
5.4 服务审计	3
5.4.1 基本型服务安全要求	3
5.4.2 加强型服务安全要求	3
5.4.3 高等级服务安全要求	3
5.5 服务变更	4
5.5.1 基本型安全要求	4
5.5.2 加强型服务安全要求	4
5.5.3 高等级服务安全要求	4
5.6 服务评估	4
5.6.1 基本型服务安全要求	4
5.6.2 加强型服务安全要求	4
5.6.3 高等级服务安全要求	4
参考文献	5

前 言

GB/T 34080《基于云计算的电子政务公共平台安全规范》分为以下 4 个部分：

- 第 1 部分：总体要求；
- 第 2 部分：信息资源安全；
- 第 3 部分：服务安全；
- 第 4 部分：应用安全。

本部分为 GB/T 34080 的第 3 部分。

本部分按照 GB/T 1.1—2009 给出的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本部分由中华人民共和国工业和信息化部(通信)提出并归口。

本部分起草单位：陕西省信息化工程研究院、华为技术有限公司、天津大海云科技有限公司、中国电子科技集团公司第二十八研究所、浙江华通云数据科技有限公司、中国信息通信研究院、博康智能信息技术有限公司、西安邮电大学、工业和信息化部电子第五研究所、西安未来国际信息股份有限公司、北京金山网络科技有限公司、北京元禾昆云科技有限公司、南京中冠科技服务有限公司。

本部分主要起草人：葛学锋、朱志祥、肖跃雷、王盾、崔昊、张春晖、马洪军、贺江敏、徐鸣、张磊、刘述、柳旭东、宋智军、戴向东、闫长睿。

引 言

电子政务发展正处于转变发展方式、深化应用和突出成效的关键转型期。政府职能转变和服务型政府建设对电子政务发展提出了更新、更高的要求。以云计算为代表的新兴信息技术、产业、应用不断涌现,深刻改变了电子政务发展技术环境及条件。构建基于云计算的电子政务公共平台可以充分发挥既有资源的作用和新兴信息技术潜能,加快电子政务发展创新,提高应用支撑服务能力,增强安全保障能力,减少重复建设,避免各自为政和信息孤岛。

为了使得服务使用机构能够从基于云计算的电子政务公共平台获得安全的、可用的和可持续的服务,GB/T 34080 的本部分规定了基于云计算的电子政务公共平台在提供服务过程中的服务安全要求,以保障服务使用机构对其数据和业务的管控。

基于云计算的电子政务公共平台 安全规范 第3部分：服务安全

1 范围

GB/T 34080 的本部分规定了基于云计算的电子政务公共平台的服务安全等级和服务安全要素。

本部分适用于基于云计算的电子政务公共平台所提供服务的等级认定及评估。

注：除非特殊说明，以下各章中“电子政务公共平台”均指“基于云计算的电子政务公共平台”。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改）适用于本文件。

GB/T 31167—2014 信息安全技术 云计算服务安全指南

GB/T 34078.1—2017 基于云计算的电子政务公共平台总体规范 第1部分：术语和定义

GB/T 34080.1—2017 基于云计算的电子政务公共平台安全规范 第1部分：总体要求

GB/T 34080.2—2017 基于云计算的电子政务公共平台安全规范 第2部分：信息资源安全

3 术语和定义

GB/T 34078.1—2017、GB/T 34080.1—2017 和 GB/T 34080.2—2017 界定的以及下列术语和定义适用于本文件。

3.1

服务变更 service change

包括服务升级、迁移、退出在内的变更。

3.2

服务安全 service security

电子政务公共云平台所提供服务的特性。

3.3

多因子鉴别 multi-factor authentication

通过多个因素的组合来鉴别用户的机制。

注：多个因素包括但不限于下列各个因素：口令、口令卡、U盾、指纹、虹膜、短信验证码等。

4 服务安全等级划分

根据 GB/T 31167—2014 的 6.4 对政府业务分类的定义，电子政务公共云平台服务安全等级可划分为以下三级：

- a) 基本型服务安全：电子政务公共云平台所提供的服务应能够满足开展一般政务业务所具备的安全能力；
- b) 加强型服务安全：电子政务公共云平台所提供的服务在具备基本型服务安全要求基础上，应

能够满足开展重要政务业务所具备的安全能力；

- c) 高等级服务安全:电子政务公共云平台所提供的服务在具备加强型服务安全要求基础上,应能够满足开展关键政务业务所具备的安全能力。

5 服务安全要求

5.1 服务访问控制

5.1.1 基本型服务安全要求

基本型服务安全要求包括:

- a) 应对服务使用机构的人员进行身份认证和鉴别;
- b) 应对服务账号指定访问权限和其他需要的属性进行鉴别;
- c) 应对服务启用访问控制功能和非法连接过滤功能,只允许合法的请求访问;
- d) 应对服务的所有外部接口进行标识和保护,防止通过这些服务接口进行攻击;
- e) 对服务未成功的登录尝试超过上限次数时,应进行锁定账户、告警通知等访问控制;
- f) 应对服务的远程访问方式进行授权控制,明确使用限制、配置和连接要求。

5.1.2 加强型服务安全要求

加强型服务安全要求包括:

- a) 应对服务的账号进行基于角色的分域、分级、分权的访问控制管理;
- b) 应对服务的账户增强安全技术保护,防止对账户信息的暴力破解;
- c) 应对服务的并发会话进行控制,不准许服务账号有两个或两个以上的并发会话;
- d) 应对服务的远程访问进行多重条件限制,自动监控和控制远程访问会话,保证远程访问会话的保密性和完整性;
- e) 应提供基于密码的安全服务,加强对服务资源的访问安全保护,保护服务资源的机密性、完整性和不可抵赖性。

5.1.3 高等级服务安全要求

高等级服务安全要求包括:

- a) 应对服务使用机构的人员进行基于实名唯一标识的认证和多因子鉴别;
- b) 应对服务使用机构的设备进行基于终端唯一标识的认证和多因子鉴别;
- c) 应对提供服务所依托的服务资源进行基于资源唯一标识的认证和多因子鉴别;
- d) 应对提供服务所依托的服务资源进行统一访问控制管理。

5.2 服务传递保护

5.2.1 基本型服务安全要求

基本型服务安全要求包括:

- a) 应对服务来源进行识别和保护,防止通过不明服务来源进行攻击;
- b) 应对服务传递过程中的内容进行安全技术保护,防止对服务传递内容的暴力破解。

5.2.2 加强型服务安全要求

加强型服务安全要求包括:

- a) 应对服务传递过程中的攻击行为进行有效拦截,防止攻击、劫持,篡改;

- b) 应对服务传递过程进行监控,对异常传递过程进行报警。

5.2.3 高等级服务安全要求

同 5.2.1 和 5.2.2。

5.3 服务监控

5.3.1 基本型服务安全要求

基本型服务安全要求包括:

- a) 应制定服务安全监控策略和规范,规定监控的主体、范围、责任等内容;
- b) 应实时监测服务的资源、重要行为、运行状态、安全事件等;
- c) 应对服务监管中异常状况进行报警。

5.3.2 加强型服务安全要求

加强型服务安全要求包括:

- a) 应及时审查和更新监控策略及相关规程;
- b) 应结合服务评估结果和审计结果及时调整监控策略。

5.3.3 高等级服务安全要求

同 5.3.1 和 5.3.2。

5.4 服务审计

5.4.1 基本型服务安全要求

基本型服务安全要求包括:

- a) 应制定审计策略和规范,包括审计主体、范围、人员、责任等内容;
- b) 应根据安全需求和服务使用机构要求,制定可审计事件清单,记录并维护审计记录;
- c) 应对审计记录进行保护,避免受到未预期的删除、修改或覆盖等;
- d) 应保证所提供审计数据的真实性;
- e) 应对审计记录进行审查和分析,定期提供审计分析报告。

5.4.2 加强型服务安全要求

加强型服务安全要求包括:

- a) 应指定独立的安全审计人员负责管理审计记录,并在授予审计人员访问权限之前对其进行审查并定期复查;
- b) 应根据法律法规及服务使用机构的要求进行审计记录的保存;
- c) 应定期审查和调整审计策略;
- d) 当法律法规、服务使用机构需求或服务面临的威胁环境发生变化时,应及时调整审计策略;
- e) 应加强审计数据的保护。

5.4.3 高等级服务安全要求

高等级服务安全要求包括:

- a) 应保证所提供审计数据的完整性;
- b) 应支持第三方审计。

5.5 服务变更

5.5.1 基本型安全要求

基本型安全要求要求包括：

- a) 服务升级时,应确保服务使用的连续性和一致性,同时服务使用机构的数据不丢失;
- b) 服务退出时,应全部返还服务使用机构的所有数据,同时销毁服务使用机构的数据,并确保数据不可恢复;
- c) 服务迁移时,应采取相关安全措施确保服务迁移过程中数据机密性和完整性,同时销毁服务使用机构的数据,并确保数据不可恢复;
- d) 服务变更时,应确保服务使用机构对其数据的所有权不变,防止未授权的访问和使用。

5.5.2 加强型服务安全要求

应提供自动化服务变更手段。

5.5.3 高等级服务安全要求

服务升级和迁移时,当数据完整性错误时,应能够采取相应的恢复措施。

5.6 服务评估

5.6.1 基本型服务安全要求

基本型服务安全要求包括：

- a) 应定期开展风险评估,或者在服务变更时,或者在出现其他可能影响服务安全状态的条件时,重新进行风险评估;
- b) 应将风险评估结果记录在风险评估报告中,并将风险评估结果发布至相关人员;
- c) 应根据风险评估报告,有针对性地服务进行安全整改。

5.6.2 加强型服务安全要求

同 5.6.1。

5.6.3 高等级服务安全要求

应引入第三方机构开展安全服务认证和评估工作,对服务安全进行评价。

参 考 文 献

- [1] GB/T 34078.2 基于云计算的电子政务公共平台总体规范 第2部分：顶层设计导则
-